
USDai Governance Contracts Security Review



Prepared by: Kais Tlili, Independent Security Researcher
ktl@tlili.net

Date: Mar 12th to Mar 27th, 2026

Contents

1. Introduction

2. Scope

3. Risk Classification

4. Executive Summary

5. Findings

5.1 Low

5.1.1 Mint/Burn bridging pattern in `Chip.sol` could lead to an artificially low quorum

1. Introduction

USDai Governance is a token-based governance system for the USDai protocol. Chip is an ERC-20 governance token that holders can stake into the StakedChip ERC-4626 vault. Token holders delegate voting power to participate in on-chain proposals through the ChipGovernor, which enforces quorum and voting periods. Approved proposals are executed via a TimelockController that enforces a mandatory delay before execution.

2. Scope

repo: <https://github.com/usdai-foundation/usdai-governance-contracts>

commit hash: 9bce81d58bb62a7f87db6c2d1b41ece6694837b7

```

├─ Chip.sol
├─ ChipGovernor.sol
├─ StakedChip.sol
├─ TimelockController.sol
├─ interfaces
│   └─ IChip.sol
│   └─ IMintableBurnable.sol
│   └─ IStakedChip.sol
└─ omnichain
    └─ OAdapter.sol
    └─ OToken.sol

```

3. Risk Classification

Severity level	Impact: high	Impact: medium	Impact: low
Likelihood: high	critical	high	medium
Likelihood: medium	high	medium	low
Likelihood: low	medium	low	low

3.1 Impact

- High: leads to a loss of a significant portion (>10%) of assets in the protocol, or significant harm to a majority of users.
- Medium: global losses <10% or losses to only a subset of users, but still unacceptable.
- Low: losses will be annoying but bearable -- applies to things like griefing attacks that can be easily mitigated without code changes or even gas inefficiencies.

3.2 Likelihood

- High: almost certain to happen, easy to perform, or not easy but highly incentivized.
- Medium: only conditionally possible or incentivized, but still relatively likely.
- Low: there are rare events but are theoretically possible under certain extreme but realistic market conditions

4. Executive Summary

Summary

Project Name	USDai Governance Contracts
Repository	usdai-governance-contracts
Commit	9bce81d
Type of Project	Governance
Review Timeline	March 12th to March 27th, 2026

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	1	0
Informational	0	0	0

5. Findings

5.1 Low

5.1.1 Mint/Burn bridging pattern in `Chip.sol` could lead to an artificially low quorum

Severity: Low

Context: <https://github.com/usdai-foundation/usdai-governance-contracts/blob/main/src/Chip.sol>

Description: In `GovernorVotesQuorumFraction.quorum()`, the past total supply is used to calculate the needed quorum:

```
/**
 * @dev Returns the quorum for a timepoint, in terms of number of votes:
 * `supply * numerator / denominator`.
 */
function quorum(uint256 timepoint) public view virtual override returns
(uint256) {
    return Math.mulDiv(token().getPastTotalSupply(timepoint),
    quorumNumerator(timepoint), quorumDenominator());
}
```

With the current bridging mint/burn mechanism it leads to artificially lowering the needed quorum when `Chip` tokens are bridged away from the chain where governance is deployed. In case a big percentage of `Chip` tokens are bridged away it could allow a malicious proposal to pass with much less than the intended 4% of total supply.

As a side effect the current bridging mechanism also causes the quorum to be unpredictable as it will be constantly changing due to users bridging in-out.

Recommendation: Consider using the lock/unlock bridging mechanism.

USDai Team: Fixed in <https://github.com/usdai-foundation/usdai-governance-contracts/commit/0bd17e19c0696572bd2e55f4ad4f18bac1790136>